ناس لايف

حزمة الأمان: النسخ الاحتياطي وسلامة المال ومفاتيح الإطفاء

ناس لايف • 21 أكتوبر 2026

إعداد: عمرو حسن شعيب • Amr Hassan Shuaib
شركة أريب الرقمية • Areeb Digital
naslife.app

حزمة الأمان: النسخ الاحتياطي وسلامة المال ومفاتيح الإطفاء

التاريخ: 21 أكتوبر 2026 • **المرجع**: القسمان 3.7 و6 وخارطة الطريق «الآن» في `docs/reports/naslife_audit_2026-09-24.md` • **الفرع**: `claude/intelligent-hypatia-owb3fk`

1. الخلاصة

نُفذت الحزمة الأولى من خارطة الطريق: أول نسخ احتياطي حقيقي للمنصة مع تمرين استعادة أسبوعي، وإغلاق ثماني ثغرات مؤكدة في مسارات المال، وإطفاء التحويل بين المستخدمين والدفع في المحادثة افتراضياً بقرار تنظيمي مع حدود جديدة لشحن البطاقة. كل جزء نُفذ في مسار مستقل، ثم راجعه مراجع عدائي مستقل يحاول كسره، ثم أُصلحت نتائج المراجعة قبل الدمج. المراجعة أمسكت بخطأين خطيرين قبل أن يصلا إلى الخادم: تمرين الاستعادة كان يمكن في مسار فشل نادر أن يحذف قاعدة البيانات الحية، وسباق بين إلغاء طلب ونزاع عليه كان يمكن أن يستردّ المبلغ للمشتري ويحرّره للبائع معاً.

ما يحتاجه المالك (التفاصيل في القسم 6): 1. تشغيل أمر واحد على الخادم لتثبيت النسخ الاحتياطي. 2. قرار مكان النسخة خارج الخادم (Backblaze B2 بنحو 6 دولارات للتيرابايت شهرياً، أو Hetzner Storage Box) وإدخال مفتاحه في ملف على الخادم. 3. مراجعة مفاتيح المال في لوحة الإدارة بعد النشر: التحويل ودفع المحادثة صارا مطفأين ما لم تفعّلهما بنفسك.

2. النسخ الاحتياطي (جديد كلياً)

قبل اليوم لم يكن في المنصة أي `pg_dump` ولا نسخة للوسائط؛ القاعدة والوسائط ونواة Node (التي ليست في git) كلها على قرص واحد.

ما يُحفظ كل ليلة (03:30 بتوقيت الرياض) 1. قاعدة البيانات كاملة بصيغة `pg_dump -Fc` مع بصمة sha256 بجانبها. يُحتفظ بآخر 14 يوماً. 2. لقطة من مجلد الوسائط بروابط صلبة (الملف الذي لم يتغير لا يُنسخ مرتين). يُحتفظ بآخر 7 لقطات. 3. الإعداد الذي لا يمكن إعادة بنائه من git: مفتاح تشفير عبارات الاسترداد `auth-key`، ملف Caddy، نواة الخادم `/opt/naslife/src` مضغوطة، ووحدات systemd. 4. مزامنة خارج الخادم إن ضُبطت وجهة (القسم 6). 5. ملف حالة `last.json` تقرأه لوحة الإدارة.

التمرين الأسبوعي (الأحد 04:30): يستعيد أحدث نسخة في قاعدة مؤقتة، يعدّ الجداول والصفوف ويقارن عدد المستخدمين بالقاعدة الحية، ثم يحذف القاعدة المؤقتة ويسجّل النتيجة. يحميه حارس يرفض اسم القاعدة الحية أو قواعد النظام قبل أي حذف، وخط دفاع ثانٍ من Postgres نفسه (الاتصال عبر القاعدة الحية يمنع حذفها).

البطاقة في اللوحة: نظرة عامة ← «النسخ الاحتياطي»: آخر نسخة قبل كم ساعة، حجم القاعدة، عدد ملفات الوسائط، هل توجد نسخة خارج الخادم، وآخر تمرين استعادة. تتحول إلى تحذير أحمر إن تجاوز عمر النسخة 30 ساعة أو فشلت.

ما أمسكته المراجعة وأُصلح: حذف القاعدة الحية في مسار فشل الحارس (أُعيدت كتابة الحارس وأُضيفت 16 حالة اختبار تثبت أن النسخة القديمة من السكربت كانت تسقط فيها)، تضخّم النسخة خارج الخادم بسبب فك الروابط الصلبة (الآن تُرفع القاعدة والإعداد وأحدث لقطة وسائط فقط)، وبقايا ملفات جزئية عند فشل التفريغ.

الملفات: `server/backup.sh`، `server/install-backup.sh`، `server/backups.js`، `server/test/harness_backups.mjs` (62 حالة)، `test/admin_backups_test.dart`، `docs/ops-backup.md` (التثبيت والاستعادة خطوة بخطوة).

3. سلامة المال (ثماني ثغرات مؤكدة أُغلقت)

#	المشكلة كما كانت	الإصلاح	أثره على المستخدم
1	تحويلان متقابلان في اللحظة نفسها يتعطلان بخطأ 500 (تعارض أقفال)	قفل المحفظتين بترتيب ثابت وإعادة المحاولة عند التعارض	لا خطأ؛ اختبار 20 تحويلاً متوازياً كلها تنجح والمجموع محفوظ
2	إلغاء المضيف لفعالية بعد أن أنفق الإيراد يفشل بخطأ خادم	فحص الرصيد قبل أي تغيير ورسالة واضحة بالمبلغ الناقص	«رصيد محفظتك لا يكفي لاسترداد التذاكر للمشترين؛ اشحن المحفظة ثم أعد المحاولة»
3	استرداد طلب السوق يمكن أن يُطبَّق مرتين أو بعد الاكتمال	شرط الحالة داخل المعاملة نفسها قبل أي قيد	إلغاء مكرر أو متأخر يُرفض بلا أثر مالي
4	سباق إلغاء ونزاع يستردّ للمشتري ويحرّر للبائع معاً (اكتشفته المراجعة)	النزاع لا يُفتح إلا على طلب ما زال قائماً، ومراحل البائع مشروطة بالحالة التي فُحصت	لا يمكن سك مال من سباق
5	فحص المخزون والموعد خارج المعاملة: طلبان متزامنان على قطعة واحدة ينجحان	قفل صف العرض داخل المعاملة	طلب واحد ينجح والآخر «نفد المخزون» أو «الموعد محجوز»
6	رمز التسليم (4 أرقام) قابل للتخمين بلا حد	عدّاد ذري: بعد 5 محاولات خاطئة يُقفل الرمز للبائع، والمشتري يؤكد من جهته	«أُقفل رمز التسليم بعد خمس محاولات خاطئة…»
7	الطلب على دائرة لم يستلمها صاحبها يخصم من المشتري ولا يصل لأحد	يُرفض الطلب المدفوع على دائرة بلا مالك (المجاني مسموح)	«هذه الدائرة لم يستلمها صاحبها بعد فلا يمكن الدفع لها الآن»
8	الشحن التجريبي يُسك بنوع الحركة نفسه كمال البطاقة، ومسار إداري قديم يسك بلا سقف ولا تدقيق	نوع مستقل `test_topup`، رفض الشحن التجريبي حين تكون مفاتيح ميسر حية، حذف المسار القديم	المالية تفرّق المال التجريبي عن الحقيقي

ملاحظة على البند 7: الدوائر التجريبية المبذورة (إيكيا، فوكس، هيلتون…) بلا مالك، فلن يقبل التطبيق طلباً مدفوعاً عليها بعد النشر؛ هذا مقصود، فالمال كان يختفي. استلام الدائرة من اللوحة يعيد الطلب عليها.

الملفات: `server/commerce.js`، `server/business.js`، `server/test/harness_money_safety.mjs` (132 حالة تشمل سباقات متوازية حقيقية)، القسم «سلامة المال» في `docs/market.md`.

4. مفاتيح المال وحدود الشحن

المفتاح أو الحد	قبل	بعد
التحويل بين المستخدمين	مفعّل افتراضياً	**مطفأ** ما لم يُفعَّل صراحة من اللوحة؛ الخادم يغلقه حتى لو غابت الإعدادات كلها
الدفع داخل المحادثة (طلب مبلغ، تقسيم، إرسال)	مفعّل افتراضياً	**مطفأ** بالقاعدة نفسها
الشحن التجريبي	يمكن تفعيله مع مفاتيح ميسر الحية	يُرفض (409) ما دامت مفاتيح ميسر الحية مضبوطة
أدنى شحن بالبطاقة	10 ريالات	**100 ريال** (إعداد `minTopup`)
أقصى شحن بالبطاقة في المرة	يقرأ سقف الشحن التجريبي خطأً (100,000 ريال)	**5,000 ريال** (إعداد `maxCardTopup` مستقل)
سقف الشحن التجريبي في التطبيق	ثابت في الكود	يصل من الخادم مع `/wallet`
المال التجريبي في المالية	غير مميز	صف «مال تجريبي في النظام» يشمل القديم والجديد ولا يدخل في الشحن اليومي

السبب التنظيمي: التحويل بين المحافظ هو «إصدار نقود إلكترونية» عند ساما ويحتاج ترخيصاً أو مسار بوابة تقسّم للبائع (التقرير في `docs/reports/Naslife_Wallet_Payments_Report_2026-09-19.pdf`). التفعيل من اللوحة يبقى بيدك متى توفر المسار.

ما سيحدث على الموقع الحي بعد النشر: إن لم تكن قد حفظت هذين المفتاحين من اللوحة سابقاً فسيصبحان مطفأين فوراً وتختفي أزرار «تحويل» و«دفع» من المحفظة وأوامر المال من المحادثة. إن كانا محفوظين «مفعّل» من قبل فسيبقيان كذلك حتى تطفئهما. الحالة ظاهرة في سطر واحد أعلى بطاقة «المحفظة» في الإعدادات.

الملفات: `server/admin.js`، `server/market_b.js`، `lib/pages/admin/admin_settings.dart`، `lib/pages/wallet/wallet_page.dart`، `server/test/harness_money_settings.mjs` (83 حالة)، `test/money_settings_test.dart`، `docs/money-switches.md` (مرجع كل مفتاح وقائمة ما قبل المدفوعات الحقيقية).

5. الاختبارات والنشر

- التطبيق: `dart analyze` نظيف، و`flutter test` 437 اختباراً ناجحاً (كانت 419 قبل الحزمة؛ 18 اختباراً جديداً).
- الخادم: 36 حزمة خضراء على قاعدة نظيفة (منها ثلاث جديدة: النسخ الاحتياطي 62 حالة، سلامة المال 132 حالة، مفاتيح المال 83 حالة)؛ الحزم الست التي تفشل هي نفسها التي كانت تفشل قبل الحزمة لأسباب بيئية (`admin` و`admin_bootstrap` و`chat_tools` و`owner` و`share` و`hospital` بملفات تجهيز غير موجودة في الجلسة، و بشرط زمني).
- النشر: الخادم سحب الكود ونُشرت نسخة الويب (بصمة `main.dart.js` الحية `73b669404bb8` مطابقة للبناء). تحقق حي بعد النشر: `/health` سليم، `/settings/public` يعيد التحويل ودفع المحادثة **مطفأين**، مسار `/adminapi/backups` حي ويطلب جلسة مدير، والقناة الحية والفنادق تعملان كما كانتا.

6. ما يحتاجه المالك

أولاً: تثبيت النسخ الاحتياطي (أمر واحد، من PowerShell) 1. انسخ الأمر كما هو:

```
ssh root@91.108.111.246 'curl -fsSL https://raw.githubusercontent.com/AmrShuaib/naslook_app/claude/intelligent-hypatia-owb3fk/server/install-backup.sh | bash'
```

2. المتوقع في نهايته سطر يبدأ بـ `BACKUP INSTALLED status ok=true dump=` ثم .
3. افتح اللوحة ← نظرة عامة ← بطاقة «النسخ الاحتياطي» وأرسل لي صورتها.

ثانياً: نسخة خارج الخادم (بدونها تبقى النسخ على القرص نفسه الذي نحميه منه) 1. الأرخص: حساب Backblaze B2 وحاوية باسم `naslife-backups`، ثم مفتاح تطبيق. أو صندوق Hetzner Storage Box (نحو 4 يورو شهرياً للتيرابايت). 2. تكتب الوجهة والمفتاح في الملف `/opt/naslife/ops/backup.env` على الخادم (مثال كامل في `docs/ops-backup.md`). 3. تختفي العلامة الكهرمانية «لا نسخة خارج الخادم» من البطاقة في الليلة التالية.

ثالثاً: مفاتيح المال بعد النشر 1. اللوحة ← الإعدادات ← بطاقة «المحفظة»: اقرأ سطر الحالة. 2. أبقِ التحويل ودفع المحادثة مطفأين حتى قرار مسار الدفع المرخّص. 3. قبل أي مدفوعات حقيقية: أطفئ الشحن التجريبي وراجع صف «مال تجريبي في النظام» في المالية.

7. ما لم يدخل في هذه الحزمة

- حجز إيراد التذاكر حتى موعد الفعالية (اليوم يصل المضيف فوراً ويُطلب منه الاسترداد من محفظته عند الإلغاء). مقترح للحزمة التالية.
- الدفع لكل طلب عبر بوابة مرخّصة بتقسيم للبائع (ينتظر قرارك وتفعيل حساب ميسر).
- صاحب الدائرة الذي يطلب من دائرته هو نفسه يُخصم منه بلا قيد مقابل (سلوك قديم، منخفض الأثر، مسجّل).
- حزمتا اختبار قديمتان تفشلان لأسباب بيئية (المستشفى بشرط زمني يعتمد على ساعة اليوم، وخمس حزم إدارية بملفات تجهيز غير موجودة في الجلسة)؛ لم يتغير عددها قبل الحزمة وبعدها.

الخطوة التالية المقترحة: الترحيب الأول والشاشات الفارغة (المدينة، شرح الموقع، دوائر مقترحة)، ثم «استلم دائرتك في دقيقتين». تبدأ بكلمة «ابدأ».